POC: Roll Transparency Log ו-מחקר · Case 03

לפי תבנית "מחקר ו-*POC*" של מגשימים: מחקר בסיסי, חמישה פיצ'רים מרכזיים, וה-*POC* הראשון (מטרות, תוכנית, עיצוב, מימוש ומסקנות). ה-*POC* נכתב בפייתון והורץ בפועל, והמספרים כאן הם הפלט שלו. כתוב במפורש מה אמיתי ומה מדומה.

מחקר בסיסי: רצף האירועים

- החלטה: קצין רישום מאשר שינוי ברשימה (הוספה, מחיקה, תיקון) במסוף שלו, ובוחר קוד סיבה מתוך רשימה סגורה.
- רשומה: המסוף בונה רשומה: מספר רץ, כינוי הבוחר (HMAC של מספר תעודת הבוחר עם מפתח סודי), קוד הפעולה והסיבה, קלפי, תאריך, וכינוי הקצין.
- הוספה ליומן: הרשומה נכנסת לעץ מרקל כ"עלה", והעץ מתעדכן.
- ראש עץ חתום: כל כמה דקות היומן חותם על הגודל והשורש הנוכחיים ומפרסם אותם.
- הודעה: הבוחר מקבל SMS עם קוד הסיבה והתאריך האחרון לערעור.
- בדיקה: הבוחר (או אפליקציה בשמו) מבקש הוכחת הכללה ובודק אותה מול ראש העץ. מוניטורים מבקשים הוכחת עקביות בין ראש עץ ישן לחדש.

מחקר בסיסי: רכיבי המערכת

- **Officer Terminal**: נקודת ההחלטה. אין שינוי ברשימה בלי רשומה.
- **Log Server**: עץ המרקל, הפקת הוכחות, חתימה על ראשי עץ.
- **Pseudonym Service** (ב-**HSM**): מחשב את כינוי הבוחר, ומחזיק את המפתח שבלעדיו אי אפשר להפוך כינוי לזהות.
- **Voter Lookup**: פורטל, SMS וקיוסק.
- **Monitors**: גופים עצמאיים שמחזיקים עותק של ראשי העץ ומשווים.

מחקר בסיסי: אתגרי אבטחה

- שכתוב שקט: מי שמנהל את היומן מנסה לשנות רשומה ישנה. ההגנה: הוכחות עקביות ומוניטורים שמחזיקים ראשי עץ ישנים.
- תצוגה מפוצלת: היומן מראה לבוחר אחד עץ אחד ולמוניטור עץ אחר. ההגנה: ראשי העץ נחתמים ומופצים, והמוניטורים "מרכלים" ביניהם.
- רשומה שלא נכתבה בכלל: שינוי ברשימה שעוקף את היומן. ההגנה: הרשימה עצמה נגזרת מהיומן (אין מסלול שינוי אחר).
- פרטיות: יומן ציבורי של מי זז, ומתי, הוא גם מידע על אנשים. ההגנה: כינויים שלא ניתנים להפיכה, קודים גסים, ועיכוב פרסום.

מחקר בסיסי: השוואה למתחרה המוביל (רשימת המחוקים שפורסמה בביהאר)

- שקיפות: שתיהן מפרסמות מחיקה עם סיבה.
- שלמות לאורך זמן: רשימה פורסמה פעם אחת, ואין דרך לדעת אם שונתה אחר כך. ביומן, כל שינוי בעבר נתפס.
- הודעה: ברשימה צריך לחפש. ביומן הבוחר מקבל הודעה.
- פרטיות: הרשימה בביהאר כללה שמות. ביומן אין שמות.

מסקנת ההשוואה: אנחנו מוסיפים הוכחה ומשנים את כיוון הזרימה (מהבוחר שמחפש, לבוחר שמקבל).

מחקר בסיסי: סוגיה אתית

יומן של מחיקות עם סיבה יכול לשמש גם לרעה: בקלפי קטנה, שורה של R-SHIFT עם תאריך מספרת לשכנים מי עזב ומתי, ושורה של R-DEAD מגיעה לפעמים לפני שהמשפחה סיפרה. התגובה: ביומן הציבורי מתפרסמים

רק מחוז ושבוע, והפרטים המלאים רק בהוכחה שהבוחר מקבל על עצמו. זה הנושא המרכזי של הערכת ההשפעה על הפרטיות (DPIA).

חמישה פיצ'רים מרכזיים

- בניית רשומה: קלט: החלטת קצין. פלט: רשומה קנונית (JSON ממוין, בלי רווחים). איך: שדות קבועים, כינוי במקום מזהה.
- הוספה לעץ: קלט: רשומה. פלט: גיבוב עלה ושורש חדש. איך: `H(0x00||entry)` לעלה, `H(0x01||L||R)` לצומת, לפי RFC 6962.
- הוכחת הכללה: קלט: מיקום הרשומה וגודל העץ. פלט: רשימת גיבובים. איך: מסלול ביקורת לפי RFC 9162 §2.1.3.
- הוכחת עקביות: קלט: גודל ישן וגודל חדש. פלט: רשימת גיבובים. איך: SUBPROOF לפי RFC 6962 §2.1.2.
- ראש עץ חתום: קלט: גודל ושורש. פלט: חתימה. איך: Ed25519 בפריסה (ב-HMAC: POC).

ה-POC: שאלת המחקר

האם יומן מרקל יכול להחזיק רשימה בגודל של מדינה, לתת לכל בוחר הוכחה קצרה שאפשר לבדוק בטלפון, לתפוס שכתוב של רשומה ישנה, ולא לחשוף פרטים אישיים?

ה-POC: מטרות

- קנה מידה: מיליון רשומות, הוכחה קצרה, בדיקה מהירה.
- הכללה: בוחר מוצא את הרשומה שלו לפי כינוי, ומאמת אותה. רשומה מזויפת לא עוברת.
- שכתוב: שינוי של רשומה אחת ישנה נתפס בהוכחת העקביות.
- פרטיות: למדוד מה אפשר ללמוד מהיומן הציבורי.

ה-POC: טכנולוגיות ומגבלות

- פייתון טהור, `hashlib` ו-`hmac` בלבד, כדי שירוץ בדפדפן.
- מגבלה חשובה: הרשימה, הבוחרים והשינויים מדומים (מ-seed קבוע). הגיבוב וההוכחות אמיתיים. החתימה על ראש העץ מדומה ב-HMAC (בפריסה Ed25519). השרת, המוניטורים והבוחר רצים באותו תהליך.
- מחוץ להיקף: רשת אמיתית, ריכול בין מוניטורים, אחסון קבוע, הודעות SMS.

ה-POC: זרימה

החלטת קצין → רשומה קנונית עם כינוי → עלה בעץ → ראש עץ חתום → הוכחת הכללה לבוחר · הוכחת עקביות למוניטור

ה-POC: מימוש (עיקרי הקוד)

```
def leaf_hash(entry): return H(b"\x00" + entry)
def node_hash(l, r): return H(b"\x01" + l + r)
def voter_tag(epic): return hmac.new(SALT, epic.encode(), sha256).hexdigest()[:20]
log.append(entry)                # incremental, complete subtrees only
p = log.inclusion(m)             # audit path
verify_inclusion(leaf, m, n, p, root)
verify_consistency(m, n, log.consistency(m), old_root, new_root)
```

ה-POC: תוצאות

מעבדה	מה מדדנו	תוצאה
קנה מידה	מיליון רשומות	בנייה ב-18.8 שניות, הוכחה של 20

גיבובים (640 בתים), בדיקה ב-0.03 מילישנייה		
27 גיבובים להוכחה	הקרנה ל-130 מיליון	קנה מידה
נמצאה ואומתה, 16 גיבובים	רשומה של פריה (מיקום 31,337 מתוך 50,000)	הכללה
ההוכחה נכשלת	אותה רשומה עם סיבה מזויפת (R-DEAD)	הכללה
נתפס: הוכחת העקביות נכשלת	שינוי רשומה 4,242 אחרי שהיומן גדל מ-12,000 ל-20,000	שכתוב
כמעט כל קלפי עם פחות מ-5 שינויים: קלפי ותאריך מזהים שכנים	50,000 רשומות על פני כ-41,000 קלפיות	פרטיות

ה-POC: מסקנות

- ✅ קנה מידה: הוכח, עם מרווח עצום. גם ב-130 מיליון ההוכחה קטנה מתמונה אחת ב-SMS.
- ✅ הכללה ושכתוב: הוכחו. זה הלב של הרעיון, והוא עובד.
- ⚠️ פרטיות: הממצא החשוב של המעבדה. כינוי לבדו לא מספיק: קלפי ותאריך הם "מזהה עקיף". מכאן החלטה שעוברת לאפיון: ביומן הציבורי מתפרסמים רק מחוז ושבוע. הקלפי והתאריך המדויק מופיעים רק בהוכחה שהבוחר מקבל על עצמו. ונכתבת הערכת השפעה על פרטיות (DPIA) כמסמך נפרד.

מסקנה: ✅ שורד, ועובר לאפיון עם דרישת פרטיות מחייבת.